LohnLab Cockpit as a Service-Vertrag

zwischen

der LohnLab GmbH,

vertreten durch die Geschäftsführer Michael Schmitt und Holger Plümer,

Hauptstr. 20, 63755 Alzenau

(im Folgenden "**Anbieter**")

und

(im Folgenden "**Unternehmen**")

(Anbieter und Unternehmen einzeln jeweils auch „**Partei**“ und gemeinsam „**Parteien**“)

§ 1 Vertragsgegenstand

Gegenstand des Vertrags ist die entgeltliche und zeitlich auf die Dauer des Vertrags begrenzte Gewährung der Nutzung der „LohnLab Cockpit“ Software (nachfolgend „Software“) über das Internet im Unternehmen sowie die Bereitstellung von Speicherplatz auf den Servern des Anbieters oder dessen Dienstleister.

§ 2 Leistungen des Anbieters; Software und Speicherplatz

(1) Der Anbieter gewährt dem Unternehmen die Nutzung der jeweils aktuellsten Version der Software für die vereinbarte Anzahl an berechtigen Nutzern über das Internet mittels Zugriff durch einen Browser.

(2) Der Anbieter gewährleistet die Funktionsfähigkeit und Verfügbarkeit der Software während der Dauer des Vertragsverhältnisses und wird diese in einem zum vertragsgemäßen Gebrauch geeigneten Zustand erhalten. Der Funktionsumfang der Software sowie die Einsatzbedingungen ergeben sich aus **Anlage 1** zu diesem Vertrag.

(3) Das Unternehmen kann nach Bedarf die Anzahl der berechtigen Unternehmen-Nutzer (“User”) der Software erhöhen, indem er weitere User einlädt, oder reduzieren. Der Anbieter wird dem Unternehmen nach Vertragsschluss unverzüglich in elektronischer Form Zugangsdaten für die entsprechende Anzahl an berechtigen Nutzern übermitteln.

(4) Der Anbieter stellt den Nutzern nach Vertragsschluss in elektronischer Form eine Benutzerdokumentation zur Verfügung. Die Benutzerdokumentation ist zudem während der Nutzung der Software jederzeit einsehbar.

(5) Der Anbieter kann, ohne hierzu verpflichtet zu sein, die Software jederzeit aktualisieren oder weiterentwickeln und insbesondere aufgrund geänderter Rechtslage, technischer Entwicklungen oder zur Verbesserung der IT-Sicherheit anpassen. Der Anbieter wird dabei die berechtigten Interessen des Unternehmens angemessen berücksichtigen und das Unternehmen rechtzeitig über notwendige Updates informieren. Im Falle einer wesentlichen Beeinträchtigung der berechtigten Interessen des Unternehmens steht diesem ein Sonderkündigungsrecht zu.

(6) Eine Anpassung auf die individuellen Bedürfnisse oder die IT-Umgebung des Unternehmens schuldet der Anbieter nicht.

(7) Der Anbieter wird die Software regelmäßig warten und das Unternehmen über etwaige hiermit verbundene Einschränkungen rechtzeitig informieren. Die Wartung wird regelmäßig außerhalb der üblichen Geschäftszeiten des Unternehmens durchgeführt, es sei denn, aufgrund zwingender Gründe muss eine Wartung zu einer anderen Zeit vorgenommen werden.

(8) Der Anbieter stellt dem Unternehmen zur Ablage von Daten und für Zwecke der Nutzung der Software Speicherplatz auf seinen Servern für den Import von Informationen, die Nutzung der Softwarefunktionen erforderlich sind, zur Verfügung. Der Anbieter wird für die Abrufbarkeit der Daten im Rahmen der Nutzung der Software sorgen.

(9) Der Anbieter wird dem Stand der Technik entsprechende Maßnahmen zum Schutz der Daten vornehmen. Den Anbieter treffen jedoch keine Verwahrungs- oder Obhutspflichten hinsichtlich der Daten. Für eine ausreichende Sicherung der Daten ist das Unternehmen verantwortlich.

(10) Das Unternehmen bleibt Inhaber der auf den Servern des Anbieters abgelegten Daten und kann diese jederzeit herausverlangen.

§ 3 Nutzungsumfang und -rechte

(1) Eine physische Überlassung der Software an das Unternehmen erfolgt nicht.

(2) Das Unternehmen erhält an der jeweils aktuellsten Version der Software, zeitlich auf die Dauer des Vertrags beschränkte Rechte, die Software mittels Zugriffes über einen Browser nach Maßgabe der vertraglichen Regelungen zu nutzen. Darüber ist das Unternehmen nicht berechtigt, die Software unterzulizenzieren oder zu übertragen.

(3) Das Unternehmen darf die Software nur im Rahmen ihrer eigenen geschäftlichen Tätigkeit durch eigenes Personal nutzen. Eine weitergehende Nutzung der Software durch das Unternehmen ist nicht gestattet.

§ 4 Support

Der Anbieter richtet für Anfragen des Kunden zu Funktionen der Software einen Support-Service ein. Anfragen können E-Mail an service@lohnlab.de oder im Service-Portal gestellt

werden. Die Anfragen werden grundsätzlich in zeitlicher Reihenfolge ihres Eingangs bearbeitet. Der Anbieter bemüht sich, Anfragen so schnellstmöglich zu beantworten.

§ 5 Service Levels; Störungsbehebung

(1) Der Anbieter gewährt eine Gesamtverfügbarkeit der Leistungen von mindestens 99,5% im Monat am Übergabepunkt. Der Übergabepunkt ist der Routerausgang des Rechenzentrums des Anbieters.

(2) Als Verfügbarkeit gilt die Möglichkeit des Kunden, sämtliche Hauptfunktionen der Software zu nutzen. Wartungszeiten sowie Zeiten der Störung unter Einhaltung der Behebungszeit gelten als Zeiten der Verfügbarkeit der Software. Zeiten unerheblicher Störungen bleiben bei der Berechnung der Verfügbarkeit außer Betracht. Für den Nachweis der Verfügbarkeit sind die Messinstrumente des Anbieters im Rechenzentrum maßgeblich.

(3) Das Unternehmen hat Störungen unverzüglich an service@lohnlab.de oder über den Feedback-Button in der Software zu melden. Eine Störungsmeldung und -behebung ist Montag bis Freitag (ausgenommen bundesweite Feiertage) zwischen 9:00 Uhr und 18:00 Uhr gewährleistet (Servicezeiten).

(4) Der Anbieter bemüht sich, Störungen zügig zu beheben.

(6) Die Beseitigung von unerheblichen Störungen liegt im Ermessen des Anbieters.

(7) Etwaige sonstige gesetzliche Ansprüche des Kunden gegen den Anbieter bleiben unberührt.

§ 6 Pflichten des Unternehmens

(1) Das Unternehmen hat die ihm übermittelten Zugangsdaten dem Stand der Technik entsprechend vor Zugriffen Dritter zu schützen und zu verwahren. Das Unternehmen wird dafür sorgen, dass eine Nutzung nur im vertraglich vereinbarten Umfang geschieht. Ein unberechtigter Zugriff ist dem Anbieter unverzüglich mitzuteilen.

(2) Das Unternehmen ist verpflichtet, auf dem zur Verfügung gestellten Speicherplatz keine Daten abzulegen, deren Nutzung gegen geltendes Recht, behördliche Anordnungen, Rechte Dritter oder Vereinbarungen mit Dritten verstößt.

(3) Das Unternehmen wird die Daten vor deren Ablage oder Nutzung in der Software auf Viren oder sonstige schädliche Komponenten prüfen und hierfür dem Stand der Technik entsprechende Maßnahmen (zB Virenschutzprogramme) einsetzen.

(4) Das Unternehmen hat in eigener Verantwortung regelmäßig angemessene Datensicherungen vorzunehmen.

§ 7 Gewährleistung

(1) Hinsichtlich der Gewährung der Nutzung der Software sowie der Zurverfügungstellung von Speicherplatz gelten die Gewährleistungsvorschriften des Mietrechts (§§ 535 ff. BGB).

(2) Das Unternehmen hat dem Anbieter jegliche Mängel unverzüglich anzuzeigen.

(3) Die Gewährleistung für nur unerhebliche Minderungen der Tauglichkeit der Leistung wird ausgeschlossen. Die verschuldensunabhängige Haftung gem. § 536a Abs. 1 BGB für Mängel, die bereits bei Vertragsschluss vorlagen, ist ausgeschlossen.

§ 8 Haftung

(1) Die Parteien haften unbeschränkt bei Vorsatz, grober Fahrlässigkeit sowie bei schuldhafter Verletzung von Leben, Körper oder Gesundheit.

(2) Unbeschadet der Fälle unbeschränkter Haftung gemäß § 8 (1) haften die Parteien einander bei leicht fahrlässiger Pflichtverletzung nur bei Verletzung wesentlicher Vertragspflichten, also Pflichten, deren Erfüllung die ordnungsgemäße Durchführung des Vertrages überhaupt erst ermöglicht oder deren Verletzung die Erreichung des Vertragszwecks gefährdet und auf deren Einhaltung die andere Partei regelmäßig vertrauen darf, allerdings beschränkt auf den bei Vertragsschluss vorhersehbaren, vertragstypischen Schaden.

(3) Die vorstehenden Haftungsbeschränkungen gelten nicht für die Haftung nach dem Produkthaftungsgesetz sowie im Rahmen schriftlich von einer Partei übernommener Garantien.

(4) § 8 gilt auch zu Gunsten von Mitarbeitern, Vertretern und Organen der Parteien.

§ 9 Rechtsmängel; Freistellung

(1) Der Anbieter gewährleistet, dass die Software keine Rechte Dritter verletzt. Der Anbieter wird das Unternehmen von allen Ansprüchen Dritter wegen von ihm zu vertretender Schutzrechtsverletzungen im Zusammenhang mit der vertragsgemäßen Nutzung der Software auf erstes Anfordern hin freistellen sowie die Kosten einer angemessenen Rechtsverfolgung ersetzen. Das Unternehmen wird den Anbieter unverzüglich über Ansprüche von Dritten, die diese aufgrund der vertragsgemäßen Nutzung der Software gegen ihn geltend machen, informieren und ihm sämtliche erforderlichen Vollmachten erteilen und Befugnisse einräumen, um die Ansprüche zu verteidigen.

(2) Das Unternehmen sichert zu, dass die auf den Servern des Anbieters abgelegten Inhalte und Daten sowie dessen Nutzung und Bereitstellung durch den Anbieter, nicht gegen geltendes Recht, behördliche Anordnungen, Rechte Dritter oder Vereinbarungen mit Dritten verstoßen. Das Unternehmen wird den Anbieter von Ansprüchen, die Dritte aufgrund eines Verstoßes gegen diese Ziffer geltend machen, auf erstes Anfordern freistellen.

§ 10 Vergütungs- und Zahlungsbedingungen

(1) Das Unternehmen hat monatlich ein Entgelt iHv 2,00 EUR je angelegtem Mitarbeiter an den Anbieter zu zahlen. Diese Vergütungspflicht ist bis zum 31.12.2025 ausgesetzt.

(3) Die Rechnungsstellung erfolgt monatlich. Die Rechnung ist innerhalb von 14 Werktagen zur Zahlung fällig.

§ 11 Vertragslaufzeit und Beendigung

(1) Der Vertrag tritt mit Unterzeichnung durch bei Parteien in Kraft und wird auf unbestimmte Zeit geschlossen.

(2) Der Vertrag kann von beiden Parteien mit einer Kündigungsfrist von 3 Monaten zum Monatsende gekündigt werden.

(3) Das Recht zur fristlosen Kündigung aus wichtigem Grund bleibt unberührt. Die Kündigung bedarf in jedem Fall der Schriftform.

(4) Der Anbieter wird sämtliche auf seinen Servern verbleibenden Daten des Unternehmens 30 Tage nach Beendigung des Vertragsverhältnisses unwiederherstellbar löschen.

§ 12 Datenschutz; Geheimhaltung

(1) Die Parteien werden die für sie jeweils geltenden anwendbaren datenschutzrechtlichen Bestimmungen einhalten.

(2) Mit Abschluss dieses Vertrages schließen die Parteien den als **Anlage 2** beigefügten Auftragsverarbeitungsvertrag.

(3) Der Anbieter verpflichtet sich, über alle vertraulichen Informationen (einschließlich Geschäftsgeheimnissen), die er im Zusammenhang mit diesem Vertrag und dessen Durchführung erfährt, Stilschweigen zu bewahren und diese nicht gegenüber Dritten offenzulegen, weiterzugeben oder auf sonstige Art zu verwenden. Vertrauliche Informationen sind dabei solche, die als vertraulich gekennzeichnet sind oder deren Vertraulichkeit sich aus den Umständen ergibt, unabhängig davon, ob sie in schriftlicher, elektronischer, verkörperter oder mündlicher Form mitgeteilt worden sind. Die Geheimhaltungsverpflichtung gilt nicht, soweit der Anbieter gesetzlich oder aufgrund bestands- bzw. rechtskräftiger Behörden- oder Gerichtsentscheidung zur Offenlegung der vertraulichen Information verpflichtet ist. Der Anbieter verpflichtet sich, mit allen Mitarbeitern und Subunternehmern eine den vorstehenden Absatz inhaltgleiche Regelung zu vereinbaren. Die Lohnkonzepte GmbH und, sofern das Unternehmen eine Betreuung der Schmitt & Hartmann OHG für sonstige Dienstleistungen ausdrücklich wünscht, diese, gelten nicht als Dritten im Sinne dieses Absatzes, soweit diese im Auftrag des Unternehmens mit Dienstleistungen im Zusammenhang mit der Lohnoptimierung oder Gehaltsabrechnung eingebunden werden.

§ 13 Schlussbestimmungen

(1) Sollten einzelne Regelungen dieses Vertrags unwirksam oder nicht durchführbar sein, bleibt die Wirksamkeit der übrigen Regelungen hiervon unberührt. Die Parteien werden solche Regelungen durch wirksame und durchführbare Regelungen ersetzen, die dem Sinn und wirtschaftlichen Zweck sowie dem Willen der Parteien bei Vertragsschluss möglichst gleichkommen. Entsprechendes gilt im Falle einer Vertragslücke.

(2) Mündliche oder schriftliche Nebenabreden zu diesem Vertrag bestehen nicht. Änderungen dieses Vertrags und seiner Anlagen bedürfen der Schriftform, die auch durch Verwendung eines eSignatur-Tools wie z.B. DocuSign oder AdobeSign erfüllt wird.

(3) Es gilt deutsches Recht unter Ausschluss der kollisionsrechtlichen Bestimmungen.

(4) Ausschließlicher Gerichtsstand für alle Streitigkeiten aus oder im Zusammenhang mit diesem Vertrag ist Aschaffenburg.

Anlagen

Anlage 1 – Funktionsbeschreibung, Kontaktdaten

Anlage 2 – Auftragsverarbeitungsvertrag

.....

Ort, Datum

.....

Unternehmen

.....

LohnLab GmbH

Anlage 1 Funktionsumfang:

1. Berechnungstools

1.1 Neueinstellungsrechner

- Berechnung von Bruttogehalt, Nettogehalt und Arbeitgeberkosten
- Integration von Lohnbausteinen (Sachbezug, Internet, Handy, Fahrtkosten, Kindergarten, etc.)
- Optimierungsvorschläge durch Lohnbausteine
- Template-System zum Speichern und Laden von Berechnungskonfigurationen
- CSV-Export der Berechnungsergebnisse
- Automatische E-Mail-Generierung für Übermittlung

1.2 Mitarbeiterrechner

- Individuelle Gehaltsoptimierung für bestehende Mitarbeiter
- Konfiguration verschiedener Lohnbausteine
- Berechnung von Einsparpotentialen

1.3 Einfacher Rechner

- Grundlegende Gehaltsberechnungen ohne Lohnbausteine

2. Mitarbeiterverwaltung

2.1 Mitarbeiter-Übersicht

- Tabellarische Darstellung aller Mitarbeiter
- Filter- und Suchfunktionen
- Detailansicht einzelner Mitarbeiter

2.2 Mitarbeiter hinzufügen

- Eingabe von Stammdaten (Personal- und Beschäftigungsdaten)
- Konfiguration von Lohnkomponenten:
- Sachbezug givve Card
- Sachbezug Fremd
- Barzuschüsse (Internet, Handy, Fahrtkosten, etc.)
- Gesamtübersicht der konfigurierten Komponenten

2.3 Mitarbeiter-Import

- CSV-Import für Massendatenübertragung
- Validierung der importierten Daten
- Fehlerbehandlung und Korrekturmöglichkeiten

3. Unternehmensverwaltung

3.1 Unternehmensdaten

- Bearbeitung von Grunddaten und Hauptsitz-Informationen

- Verwaltung von Unternehmensdokumenten
- Anzeige und Bearbeitung von Gebührenstrukturen

3.2 Givve Card Integration

- Vollständiger Onboarding-Prozess für givve Card
- Auswahl des Kartentyps
- Upload und Verwaltung rechtlicher Dokumente je nach Unternehmensform (AG, GmbH, etc.)
- Bestellformular-Generierung
- Status-Tracking des Onboarding-Fortschritts

4. Benutzerverwaltung

4.1 User Management (Admin)

- Übersicht aller Benutzer
- Benutzer einladen, bearbeiten und löschen
- Rollenverwaltung

4.2 Unternehmen-Management (Admin)

- Verwaltung aller Kundenunternehmen
- Erstellung und Bearbeitung von Unternehmensprofilen

5. Onboarding-Prozesse

5.1 Allgemeines Onboarding

- Schrittweise Einrichtung neuer Kunden
- Erfassung von Gesellschaftsdaten, Ansprechpartnern, Buchhaltungsinformationen
- givve Card Aktivierung optional

5.2 Givve Card Onboarding

- Separater, detaillierter Prozess für givve Card Setup
- Dokumenten-Upload je nach Rechtsform
- Design-Auswahl und -genehmigung

6. Authentifizierung

7. Benutzeranmeldung

- Login/Logout-Funktionalität
- Passwort-Reset
- Invite-System für neue Benutzer
- Session-Management

8. Dashboard und Navigation

8.1 Hauptdashboard

- Übersicht über alle verfügbaren Funktionen
- Benutzerkontext (Unternehmen, Rolle)
- Navigation zwischen verschiedenen Bereichen

8.2 Einstellungen

- Benutzerprofil-Verwaltung
- Persönliche Einstellungen

9. Technische Features

9.1 Template-System

- Speichern und Laden von Berechnungskonfigurationen
- Wiederverwendung häufig genutzter Einstellungen

9.2 Export-Funktionen

- CSV-Export von Berechnungsergebnissen
- Automatische E-Mail-Generierung mit vorgefüllten Daten

9.3 Responsive Design

- Mobile-optimierte Benutzeroberfläche
- Adaptive Darstellung auf verschiedenen Bildschirmgrößen

Anlage 2: Auftragsverarbeitungsvertrag

zwischen

dem Unternehmen aus dem Hauptvertrag „LohnLab Cockpit as a Service-Vertrag“

als Verantwortlicher (nachfolgend „**Verantwortlicher**“),

und

der LohnLab GmbH,

vertreten durch die Geschäftsführer Michael Schmitt und Holger Plümer,

Hauptstr. 20, 63755 Alzenau

als Auftragsverarbeiter (nachfolgend „**Auftragsverarbeiter**“,

Verantwortlicher und Auftragsverarbeiter gemeinsam die “**Parteien**”)

Präambel

Der Verantwortliche hat den Auftragsverarbeiter im bereits geschlossenen Vertrag (nachfolgend „**Hauptvertrag**“) zu den dort genannten Leistungen beauftragt. Teil der Vertragsdurchführung ist die Verarbeitung von personenbezogenen Daten. Insbesondere Art. 28 DSGVO stellt bestimmte Anforderungen an eine solche Auftragsverarbeitung. Zur Wahrung dieser Anforderungen schließen die Parteien den nachfolgenden Auftragsverarbeitungsvertrag (nachfolgend die “**Vereinbarung**”), dessen Erfüllung nicht gesondert vergütet wird, sofern dies nicht ausdrücklich vereinbart ist.

§ 1 Begriffsbestimmungen

(1) Verantwortlicher ist gem. Art. 4 Abs. 7 DSGVO die Stelle, die allein oder gemeinsam mit anderen Verantwortlichen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet.

(2) Auftragsverarbeiter ist gem. Art. 4 Abs. 8 DSGVO eine natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, die personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet.

(3) Personenbezogene Daten sind gem. Art. 4 Abs. 1 DSGVO alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person (im Folgenden „**Betroffener**") beziehen; als identifizierbar wird eine natürliche Person angesehen, die direkt oder indirekt, insbesondere mittels Zuordnung zu einer Kennung wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind, identifiziert werden kann.

(4) Besonders schutzbedürftige personenbezogene Daten sind personenbezogene Daten gem. Art. 9 DSGVO, aus denen die rassische und ethnische Herkunft, politische Meinungen, religiöse oder weltanschauliche Überzeugungen oder die Gewerkschaftszugehörigkeit von Betroffenen hervorgehen, personenbezogene Daten gem. Art. 10 DSGVO über strafrechtliche Verurteilungen und Straftaten oder damit zusammenhängende Sicherungsmaßregeln sowie genetische Daten gem. Art. 4 Abs. 13 DSGVO, biometrische Daten gem. Art. 4 Abs. 14 DSGVO, Gesundheitsdaten gem. Art. 4 Abs. 15 DSGVO sowie Daten zum Sexualleben oder der sexuellen Orientierung einer natürlichen Person.

(5) Verarbeitung ist gem. Art. 4 Abs. 2 DSGVO jeder mit oder ohne Hilfe automatisierter Verfahren ausgeführte Vorgang oder jede solche Vorgangsreihe im Zusammenhang mit personenbezogenen Daten wie das Erheben, das Erfassen, die Organisation, das Ordnen, die Speicherung, die Anpassung oder Veränderung, das Auslesen, das Abfragen, die Verwendung, die Offenlegung durch Übermittlung, Verbreitung oder eine andere Form der Bereitstellung, der Abgleich oder die Verknüpfung, die Einschränkung, das Löschen oder die Vernichtung.

(6) Aufsichtsbehörde ist gem. Art. 4 Abs. 21 DSGVO eine von einem Mitgliedstaat gem. Art. 51 DSGVO eingerichtete unabhängige staatliche Stelle.

§ 2 Vertragsgegenstand

(1) Der Auftragsverarbeiter erbringt für den Verantwortlichen die im Hauptvertrag genannten Leistungen. Dabei erhält der Auftragsverarbeiter Zugriff auf personenbezogene Daten, die der Auftragsverarbeiter für den Verantwortlichen ausschließlich im Auftrag und nach Weisung des Verantwortlichen verarbeitet. Umfang und Zweck der Datenverarbeitung durch den Auftragsverarbeiter ergeben sich aus dem Hauptvertrag und etwaigen zugehörigen

Leistungsbeschreibungen. Dem Verantwortlichen obliegt die Beurteilung der Zulässigkeit der Datenverarbeitung.

(2) Zur Konkretisierung der beiderseitigen datenschutzrechtlichen Rechte und Pflichten schließen die Parteien die vorliegende Vereinbarung. Die Regelungen der vorliegenden Vereinbarung gehen im Zweifel den Regelungen des Hauptvertrags vor.

(3) Die Bestimmungen dieses Vertrages finden Anwendung auf alle Tätigkeiten, die mit dem Hauptvertrag in Zusammenhang stehen und bei der der Auftragsverarbeiter und seine Beschäftigten oder durch den Auftragsverarbeiter Beauftragte mit personenbezogenen Daten in Berührung kommen, die vom Verantwortlichen stammen oder für den Verantwortlichen erhoben wurden.

(4) Die Laufzeit dieses Vertrags richtet sich nach der Laufzeit des Hauptvertrages, sofern sich aus den nachfolgenden Bestimmungen nicht darüber hinausgehende Verpflichtungen oder Kündigungsrechte ergeben.

§ 3 Weisungsrecht

(1) Der Auftragsverarbeiter darf Daten nur im Rahmen des Hauptvertrags und gemäß den Weisungen des Verantwortlichen erheben, verarbeiten oder nutzen. Wird der Auftragsverarbeiter durch das Recht der Europäischen Union oder der Mitgliedstaaten, dem er unterliegt, zu weiteren Verarbeitungen verpflichtet, teilt er dem Verantwortlichen diese rechtlichen Anforderungen vor der Verarbeitung mit.

(2) Die Weisungen des Verantwortlichen werden anfänglich durch diesen Vertrag festgelegt und können vom Verantwortlichen danach in schriftlicher Form oder in Textform durch einzelne Weisungen geändert, ergänzt oder ersetzt werden (Einzelweisung). Der Verantwortliche ist jederzeit zur Erteilung entsprechender Weisungen berechtigt. Dies umfasst Weisungen in Hinblick auf die Berichtigung, Löschung und Sperrung von Daten.

(3) Alle erteilten Weisungen sind vom Verantwortlichen zu dokumentieren. Weisungen, die über die hauptvertraglich vereinbarte Leistung hinausgehen, werden als Antrag auf Leistungsänderung behandelt.

(4) Ist der Auftragsverarbeiter der Ansicht, dass eine Weisung des Verantwortlichen gegen datenschutzrechtliche Bestimmungen verstößt, hat er den Verantwortlichen unverzüglich darauf hinzuweisen. Der Auftragsverarbeiter ist berechtigt, die Durchführung der betreffenden Weisung solange auszusetzen, bis diese durch den Verantwortlichen bestätigt oder geändert wird. Der Auftragsverarbeiter darf die Durchführung einer offensichtlich rechtswidrigen Weisung ablehnen.

§ 4 Arten der verarbeiteten Daten, Kreis der Betroffenen, Drittland

(1) Im Rahmen der Durchführung des Hauptvertrags erhält der Auftragsverarbeiter Zugriff auf die in **Anlage 1** näher spezifizierten personenbezogenen Daten.

(2) Der Kreis der von der Datenverarbeitung Betroffenen ist in **Anlage 2** dargestellt.

(3) Eine Weitergabe personenbezogener Daten in ein Drittland (außerhalb des EWR) darf nur unter den Voraussetzungen der Art. 44 ff. DSGVO stattfinden.

§ 5 Schutzmaßnahmen des Auftragsverarbeiters

(1) Der Auftragsverarbeiter ist verpflichtet, die gesetzlichen Bestimmungen über den Datenschutz zu beachten und die aus dem Bereich des Verantwortlichen erlangten Informationen nicht an Dritte weiterzugeben oder deren Zugriff auszusetzen. Unterlagen und Daten sind gegen die Kenntnisnahme durch Unbefugte unter Berücksichtigung des Stands der Technik zu sichern.

(2) Der Auftragsverarbeiter wird in seinem Verantwortungsbereich die innerbetriebliche Organisation so gestalten, dass sie den besonderen Anforderungen des Datenschutzes gerecht wird. Er hat die in **Anlage 3** genannten technischen und organisatorischen Maßnahmen zum angemessenen Schutz der Daten des Verantwortlichen gem. Art. 32 DSGVO getroffen, die der Verantwortliche als angemessen anerkennt. Eine Änderung der getroffenen Sicherheitsmaßnahmen bleibt dem Auftragsverarbeiter vorbehalten, wobei er sicherstellt, dass das vertraglich vereinbarte Schutzniveau nicht unterschritten wird.

(3) Den bei der Datenverarbeitung durch den Auftragsverarbeiter beschäftigten Personen ist es untersagt, personenbezogene Daten unbefugt zu erheben, zu verarbeiten oder zu nutzen. Der Auftragsverarbeiter wird alle Personen, die von ihm mit der Bearbeitung und der Erfüllung dieses Vertrages betraut werden (nachfolgend "**Mitarbeiter**"), entsprechend verpflichten (Verpflichtung zur Vertraulichkeit, Art. 28 Abs. 3 lit. b DSGVO) und mit der gebotenen Sorgfalt die Einhaltung dieser Verpflichtung sicherstellen.

(4) Der Auftragsverarbeiter hat einen Datenschutzbeauftragten benannt. Der Datenschutzbeauftragte des Auftragsverarbeiters ist heyData GmbH, Schützenstr. 5, 10117 Berlin, datenschutz@heydata.eu, www.heydata.eu.

§ 6 Informationspflichten des Auftragsverarbeiters

(1) Bei Störungen, Verdacht auf Datenschutzverletzungen oder Verletzungen vertraglicher Verpflichtungen des Auftragsverarbeiters, Verdacht auf sicherheitsrelevante Vorfälle oder andere Unregelmäßigkeiten bei der Verarbeitung der personenbezogenen Daten durch den Auftragsverarbeiter, bei ihm im Rahmen des Auftrags beschäftigten Personen oder durch Dritte wird der Auftragsverarbeiter den Verantwortlichen unverzüglich informieren. Dasselbe gilt für Prüfungen des Auftragsverarbeiters durch die Datenschutz-Aufsichtsbehörde. Die Meldung über eine Verletzung des Schutzes personenbezogener Daten enthält zumindest folgende Informationen:

a) eine Beschreibung der Art der Verletzung des Schutzes personenbezogener Daten, soweit möglich mit Angabe der Kategorien und der Zahl der betroffenen Personen, der betroffenen Kategorien und der Zahl der betroffenen personenbezogenen Datensätze;

b) eine Beschreibung der von dem Auftragsverarbeiter ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung der Verletzung und gegebenenfalls Maßnahmen zur Abmilderung ihrer möglichen nachteiligen Auswirkungen;

c) eine Beschreibung der wahrscheinlichen Folgen der Verletzung des Schutzes personenbezogener Daten.

(2) Der Auftragsverarbeiter trifft unverzüglich die erforderlichen Maßnahmen zur Sicherung der Daten und zur Minderung möglicher nachteiliger Folgen der Betroffenen, informiert hierüber den Verantwortlichen und ersucht um weitere Weisungen.

(3) Der Auftragsverarbeiter ist darüber hinaus verpflichtet, dem Verantwortlichen jederzeit Auskünfte zu erteilen, soweit dessen Daten von einer Verletzung nach Absatz 1 betroffen sind.

(4) Über wesentliche Änderung der Sicherheitsmaßnahmen nach § 5 Abs. 2 hat der Auftragsverarbeiter den Verantwortlichen zu unterrichten.

§ 7 Kontrollrechte des Verantwortlichen

(1) Der Verantwortliche kann sich vor der Aufnahme der Datenverarbeitung und sodann jährlich von den technischen und organisatorischen Maßnahmen des Auftragsverarbeiters überzeugen. Hierfür kann er z. B. Auskünfte des Auftragsverarbeiters einholen, sich vorhandene Testate von Sachverständigen, Zertifizierungen oder internen Prüfungen vorlegen lassen oder die technischen und organisatorischen Maßnahmen des Auftragsverarbeiters nach rechtzeitiger Abstimmung zu den üblichen Geschäftszeiten selbst persönlich prüfen oder durch einen sachkundigen Dritten prüfen lassen, sofern dieser nicht in einem Wettbewerbsverhältnis zum Auftragsverarbeiter steht. Der Verantwortliche wird Kontrollen nur im erforderlichen Umfang durchführen und die Betriebsabläufe des Auftragsverarbeiters dabei nicht unverhältnismäßig stören.

(2) Der Auftragsverarbeiter verpflichtet sich, dem Verantwortlichen auf dessen mündliche oder schriftliche Anforderung innerhalb einer angemessenen Frist alle Auskünfte und Nachweise zur Verfügung zu stellen, die zur Durchführung einer Kontrolle der technischen und organisatorischen Maßnahmen des Auftragsverarbeiters erforderlich sind.

(3) Der Verantwortliche dokumentiert das Kontrollergebnis und teilt es dem Auftragsverarbeiter mit. Bei Fehlern oder Unregelmäßigkeiten, die der Verantwortliche insbesondere bei der Prüfung von Auftragsergebnissen feststellt, hat er den Auftragsverarbeiter unverzüglich zu informieren. Werden bei der Kontrolle Sachverhalte festgestellt, deren zukünftige Vermeidung Änderungen des angeordneten Verfahrensablaufs erfordern, teilt der Verantwortliche dem Auftragsverarbeiter die notwendigen Verfahrensänderungen unverzüglich mit.

§ 8 Einsatz von Dienstleistern

(1) Die vertraglich vereinbarten Leistungen werden unter Einschaltung der in **Anlage 4** genannten Dienstleister (nachfolgend "**Unterauftragsverarbeiter**") durchgeführt. Der Verantwortliche erteilt dem Auftragsverarbeiter seine allgemeine Genehmigung im Sinne von Art. 28 Abs. 2 S. 1 DSGVO, im Rahmen seiner vertraglichen Verpflichtungen weitere Unterauftragsverarbeiter zu beauftragen oder bereits beauftragte zu ersetzen.

(2) Der Auftragsverarbeiter wird den Verantwortlichen vor jeder beabsichtigten Änderung in Bezug auf die Hinzuziehung oder die Ersetzung eines Unterauftragsverarbeiters informieren. Der Verantwortliche kann gegen eine beabsichtigte Hinzuziehung oder die Ersetzung eines Unterauftragsverarbeiters aus wichtigem datenschutzrechtlichen Grund Einspruch erheben.

(3) Der Einspruch gegen die beabsichtigte Hinzuziehung oder die Ersetzung eines Unterauftragsverarbeiters ist innerhalb von 2 Wochen nach Erhalt der Information über die Änderung zu erheben. Wird kein Einspruch erhoben, gilt die Hinzuziehung oder Ersetzung als genehmigt. Liegt ein wichtiger datenschutzrechtlicher Grund vor und ist eine einvernehmliche Lösungsfindung zwischen dem Verantwortlichen und dem Auftragsverarbeiter nicht möglich, steht dem Auftragsverarbeiter ein Sonderkündigungsrecht zum auf den Einspruch folgenden Monatsende zu.

(4) Der Auftragsverarbeiter hat bei der Einschaltung von Unterauftragsverarbeitern diese entsprechend den Regelungen dieser Vereinbarung zu verpflichten.

(5) Ein Unterauftragsverhältnis im Sinne dieser Bestimmungen liegt nicht vor, wenn der Auftragsverarbeiter Dritte mit Dienstleistungen beauftragt, die als reine Nebenleistungen anzusehen sind. Dazu gehören z. B. Post-, Transport- und Versandleistungen, Reinigungsleistungen, Telekommunikationsleistungen ohne konkreten Bezug zu Leistungen, die

der Auftragsverarbeiter für den Verantwortlichen erbringt und Bewachungsdienste. Wartungs- und Prüfleistungen stellen zustimmungspflichtige Unterauftragsverhältnisse dar, soweit diese für IT-Systeme erbracht werden, die auch im Zusammenhang mit der Erbringung von Leistungen für den Verantwortlichen genutzt werden.

§ 9 Anfragen und Rechte Betroffener

(1) Der Auftragsverarbeiter unterstützt den Verantwortlichen nach Möglichkeit mit geeigneten technischen und organisatorischen Maßnahmen bei der Erfüllung von dessen Pflichten nach Art. 12–22 sowie 32 bis 36 DSGVO.

(2) Macht ein Betroffener Rechte, etwa auf Auskunftserteilung, Berichtigung oder Löschung hinsichtlich seiner Daten, unmittelbar gegenüber dem Auftragsverarbeiter geltend, so reagiert dieser nicht selbstständig, sondern verweist den Betroffenen an den Verantwortlichen und wartet dessen Weisungen ab.

§ 10 Haftung

(1) Für den Ersatz von Schäden, die ein Betroffener wegen einer nach den Datenschutzgesetzen unzulässigen oder unrichtigen Datenverarbeitung oder Nutzung im Rahmen der Auftragsverarbeitung erleidet, ist im Innenverhältnis zum Auftragsverarbeiter allein der Verantwortliche gegenüber dem Betroffenen verantwortlich.

(2) Der Auftragsverarbeiter haftet für Schäden unbeschränkt, soweit die Schadensursache auf einer vorsätzlichen oder grob fahrlässigen Pflichtverletzung des Auftragsverarbeiters, seines gesetzlichen Vertreters oder Erfüllungsgehilfen beruht.

(3) Für fahrlässiges Verhalten haftet der Auftragsverarbeiter nur bei Verletzung einer Pflicht, deren Erfüllung die ordnungsgemäße Durchführung des Vertrages überhaupt erst ermöglicht und auf deren Einhaltung der Verantwortliche regelmäßig vertraut und vertrauen darf, jedoch beschränkt auf den vertragstypischen Durchschnittsschaden. Im Übrigen ist die Haftung des Auftragsverarbeiters - auch für seine Erfüllungs- und Verrichtungsgehilfen - ausgeschlossen.

(4) Die Haftungsbegrenzung gemäß § 10.3 gilt nicht für Schadensersatzansprüche aus der Verletzung von Leben, Körper, Gesundheit oder aus der Übernahme einer Garantie.

§ 11 Beendigung des Hauptvertrags

(1) Der Auftragsverarbeiter wird dem Verantwortlichen nach Beendigung des Hauptvertrags alle ihm überlassenen Unterlagen, Daten und Datenträger zurückgeben oder – auf Wunsch des

Verantwortlichen, sofern nicht nach dem Unionsrecht oder dem Recht der Bundesrepublik Deutschland eine Verpflichtung zur Speicherung der personenbezogenen Daten besteht – löschen. Dies betrifft auch etwaige Datensicherungen beim Auftragsverarbeiter. Der Auftragsverarbeiter hat den dokumentierten Nachweis der ordnungsgemäßen Löschung auf Anfrage zu führen.

(2) Der Verantwortliche hat das Recht, die vollständige und vertragsgerechte Rückgabe oder Löschung der Daten beim Auftragsverarbeiter in geeigneter Weise zu kontrollieren.

(3) Der Auftragsverarbeiter ist verpflichtet, auch über das Ende des Hauptvertrags hinaus die ihm im Zusammenhang mit dem Hauptvertrag bekannt gewordenen Daten vertraulich zu behandeln. Die vorliegende Vereinbarung bleibt über das Ende des Hauptvertrags hinaus solange gültig, wie der Auftragsverarbeiter über personenbezogene Daten verfügt, die ihm vom Verantwortlichen zugeleitet wurden oder die er für diesen erhoben hat.

§ 12 Schlussbestimmungen

(1) Soweit der Auftragsverarbeiter Unterstützungshandlungen nach dieser Vereinbarung nicht ausdrücklich kostenlos durchführt, kann er dem Verantwortlichen dafür eine angemessene Gebühr in Rechnung stellen, es sei denn, eigene Handlungen oder Unterlassungen des Auftragsverarbeiters haben diese Unterstützung unmittelbar erforderlich gemacht.

(2) Änderungen und Ergänzungen dieser Vereinbarung bedürfen der Textform. Dies gilt auch für den Verzicht auf dieses Formerfordernis. Der Vorrang individueller Vertragsabreden bleibt hiervon unberührt.

(3) Sollten einzelne Bestimmungen dieser Vereinbarung ganz oder teilweise nicht rechtswirksam oder nicht durchführbar sein oder werden, so wird hierdurch die Gültigkeit der jeweils übrigen Bestimmungen nicht berührt.

(4) Diese Vereinbarung unterliegt deutschem Recht.

Anlagen

Anlage 1 zum Auftragsverarbeitungsvertrag – Beschreibung der Daten/Datenkategorien

Im Rahmen der im Hauptvertrag festgelegten Dienstleistung verarbeitet die LohnLab GmbH personenbezogene Daten, die der Verantwortliche zur Verfügung stellt. Diese Daten umfassen Informationen über das Unternehmen, dessen Ansprechpartner sowie die Mitarbeiter des Unternehmens.

Unternehmensdaten: Unternehmensname, Unternehmensadresse

Daten der Ansprechpartner: Name, Funktion, E-Mail, Telefonnummer

Daten der Mitarbeiter: Personaldaten (Personalnummer, Name, Vorname, Adresse, Kontaktdaten, Geburtsdatum, Geschlecht, Staatsangehörigkeit), Beschäftigungsdaten (Eintrittsdatum, Austrittsdatum, Arbeitnehmertyp, Entlohnungsform, Steuer- und sozialversicherungsrechtliche Daten (Familienstand, Steuerklasse, Faktor, Anzahl der Kinder, Steuer-Freibeträge, Krankenkassennummer, Midjob-Regelung, Unfallversicherungspflicht, Private Krankenversicherung, Betriebsnummer der Krankenkasse) Lohn- und Gehaltsdaten (Lohnart und Lohnart-Bezeichnung, Betrag, Abrechnungsintervall, Stundenlohn) Kinderdaten (Vorname, Geburtsdatum), Konfessionszugehörigkeit

Anlage 2 zum Auftragsverarbeitungsvertrag – Beschreibung der Betroffenen/Betroffenengruppen

Verantwortlicher, Kunden und Mitarbeiter des Verantwortlichen, Dritte

Im Rahmen dieses Vertrages verarbeitet die LohnLab GmbH personenbezogene Daten folgender Personengruppen:

1. **Mitarbeiter des Verantwortlichen**
   a) Mitarbeitende des Verantwortlichen – Angestellte, deren Lohndaten erfasst und verarbeitet werden.
   b) Ansprechpartner im Unternehmen – Personalverantwortliche oder Administratoren, die mit dem System interagieren.

Anlage 3 zum Auftragsverarbeitungsvertrag – Technische und organisatorische Maßnahmen des Auftragsverarbeiters

1. Einleitung

Dieses Dokument fasst die vom Auftragsverarbeiter getroffenen technischen und organisatorischen Maßnahmen im Sinne von Art. 32 Abs. 1 DSGVO zusammen. Das sind Maßnahmen, mit denen der Auftragsverarbeiter personenbezogene Daten schützt. Das Dokument hat den Zweck, den Auftragsverarbeiter bei der Erfüllung seiner Rechenschaftspflicht aus Art. 5 Abs. 2 DSGVO zu unterstützen.

2. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

2.1. Zutrittskontrolle

Folgende implementierte Maßnahmen verhindern, dass Unbefugte Zutritt zu den Datenverarbeitungsanlagen haben:

- Manuelles Schließsystem (z.B. Schlüssel)
- Besucher nur in Begleitung durch Mitarbeiter
- Sorgfältige Auswahl des Reinigungspersonals

2.2. Zugangskontrolle

Folgende implementierte Maßnahmen verhindern, dass Unbefugte Zugang zu den Datenverarbeitungssystemen haben:

- Authentifikation mit Benutzer und Passwort
- Einsatz von Anti-Viren-Software

- Einsatz von VPN-Technologie bei Remote-Zugriffen
- Verwaltung von Benutzerberechtigungen
- Zwei-Faktor-Authentifizierung (2FA)
- Passwortlose Magic Link Authentifizierung: Nutzt kryptografisch gesicherte, zeitlich begrenzte OTP-Links, um Passwort-Schwachstellen (wie Phishing oder Credential Stuffing) vollständig zu eliminieren. Die Methode erfüllt die Kriterien einer Multi-Faktor-Authentifizierung (Besitz des E-Mail-Accounts und manuelle Bestätigung im Browser).

2.3. Zugriffskontrolle

Folgende implementierte Maßnahmen stellen sicher, dass Unbefugte keinen Zugriff auf personenbezogene Daten haben:

- Vernichtung von Datenträgern mindestens nach DIN 66399
- Verwaltung der Benutzerrechte durch Systemadministratoren

2.4. Trennungskontrolle

Folgende Maßnahmen stellen sicher, dass personenbezogene Daten, die zu unterschiedlichen Zwecken erhoben wurden, stets getrennt verarbeitet werden:

- **Datenbankebene – Row Level Security (RLS)**
    - Einsatz von *Supabase RLS* als fundamentaler Sicherheitsmechanismus
    - Aktiviert für alle kritischen Tabellen (z. B. companies, subsidiaries, user_profiles, company_users)
    - Automatische Filterung aller Queries durch RLS-Policies verhindert unbefugten Zugriff

- **Rollenbasiertes Berechtigungssystem**

- Drei Rollenstufen:
  - **ADMIN**: Vollzugriff auf alle Unternehmen
  - **KUNDENBETREUER**: Zugriff nur auf zugewiesene Unternehmen
  - **USER**: Zugriff ausschließlich auf das eigene Unternehmen
- Berechtigungsprüfung erfolgt server- und clientseitig (z. B. checkPermission, checkClientPermission, requirePermission)

- **API-Endpunkt-Sicherung**
  - Session-Validierung durch Middleware bei jedem Request
  - Bearer-Token-Validierung für externe APIs
  - Automatische Company-ID-Filterung in sämtlichen Datenabfragen
- **Datenabgrenzung auf Anwendungsebene**
  - Kontextbasierte Filterung nach company_id in allen Datenabfragen
  - Trennung von Dokumenten über unternehmensspezifische Speicherpfade (Struktur: {subsidiaryId}/{documentType}/)

- **Frontend-Sicherheitsmaßnahmen**
  - Zugriffskontrolle über *CompanyContext*
  - Automatische Einschränkung der Navigation je nach Benutzerrolle
  - Validierung von LocalStorage-Daten gegen Datenbankberechtigungen
  - Rollenspezifische Seitenaufrufe (UI-Beschränkungen)

- **Session- und Authentifizierungssicherheit**
  - JWT-basierte Session-Verwaltung über Supabase Auth
  - Automatisches Session-Timeout
  - Sichere Cookie-Behandlung (SSR)

- **Datenbank-Constraints**
  - Strikte referentielle Integrität durch Foreign Keys (z. B. subsidiaries.company_id → companies.id, company_users.company_id → companies.id)
  - Automatisierte Konsistenz durch CASCADE-Mechanismen

3. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

-

3.1. Weitergabekontrolle

Es ist sichergestellt, dass personenbezogene Daten bei der Übertragung oder Speicherung auf Datenträgern nicht unbefugt gelesen, kopiert, verändert oder entfernt werden können und überprüft werden kann, welche Personen oder Stellen personenbezogene Daten erhalten haben. Zur Sicherstellung sind folgende Maßnahmen implementiert:

- Übertragungssicherheit
  - Durchgängige TLS/HTTPS-Verschlüsselung für alle Datenübertragungen
  - Erzwingung von HTTPS (automatische Weiterleitung)
  - Sichere API-Kommunikation mit Supabase (verschlüsselte Verbindungen)

- API-Sicherheit
  - Bearer-Token-Authentifizierung für externe API-Aufrufe
  - Service-Role-Keys nur für administrative Vorgänge
  - Rate Limiting zur Missbrauchsverhinderung

- Speichersicherheit
  - Unternehhmententrennung im Storage durch unternehmensspezifische Ordnerstrukturen
  - Automatische Pfad-Segregation verhindert Cross-Tenant-Zugriffe
  - Sanitized Filenames zur Verhinderung von Path-Traversal-Angriffen
  - Zeitbasierte Zugriffskontrolle durch Signed URLs mit kurzer Gültigkeitsdauer (10–60 Minuten)

- Zugriffskontrolle & Protokollierung
  - Authentifizierte Dateizugriffe nur für berechtigte User
  - Automatische company_id-Filterung in allen Storage-Operationen

  - Kontextbasierte Zugriffskontrolle im Frontend
  - Logging und Monitoring aller kritischen Operationen (inkl. Request-IDs, Error-Tracking)
  - Supabase-interne Auditierung aller Datenbankzugriffe (Realtime-Monitoring)

- E-Mail-Sicherheit
  - Nutzung eines geprüften E-Mail-Providers (Resend.com)
  - Verschlüsselte SMTP-Verbindungen und validierte Absender-Domain
  - Empfänger auf interne, festgelegte Adressen beschränkt
  - Keine Weiterleitung an externe Adressen
  - Sichere Übertragung von Dateianhängen via Base64-Encoding

- Session- & Authentifizierungssicherheit
  - JWT-basierte Authentifizierung (Supabase Auth)
  - Sichere Session-Token mit kurzer Gültigkeit (1 Stunde) und automatischem Refresh
  - Zugriffskontrolle über Middleware (automatische Blockierung/Weiterleitung bei fehlender Authentifizierung)
  - Cookie-Sicherheit: HttpOnly, Secure und SameSite-Flags aktiviert

- Zusätzliche Sicherheitsmaßnahmen
  - Input-Validierung (z. B. E-Mail-Format, Datei-Typen und -größen)
  - Schutz vor SQL-Injection durch ORM-Nutzung
- Manuelle Übertragung von Daten

3.2. Eingabekontrolle

Durch folgende Maßnahmen ist sichergestellt, dass geprüft werden kann, wer personenbezogene Daten zu welcher Zeit in Datenverarbeitungsanlagen verarbeitet hat:

- Klare Zuständigkeiten für Löschungen

- Anweisung an Mitarbeiter, nur nach Rücksprache Daten zu löschen

- Protokollierung der Eingabe, Änderung und Löschung von Daten

4. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

Durch folgende Maßnahmen ist sichergestellt, dass personenbezogene Daten gegen zufällige Zerstörung oder Verlust geschützt und für den Auftraggeber stets verfügbar sind:

- Hosting (jedenfalls der wichtigsten Daten) mit einem professionellen Hoster

5. Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung (Art. 32 Abs. 1 lit. d DSGVO; Art. 25 Abs. 1 DSGVO)

5.1. Datenschutz-Management

Folgende Maßnahmen sollen gewährleisten, dass eine den datenschutzrechtlichen Grundanforderungen genügende Organisation vorhanden ist:

- Verwendung der heyData-Plattform zum Datenschutz-Management
- Bestellung des Datenschutzbeauftragten heyData
- Verpflichtung der Mitarbeiter auf das Datengeheimnis
- Regelmäßige Schulungen der Mitarbeiter im Datenschutz
- Führen einer Übersicht über Verarbeitungstätigkeiten (Art. 30 DSGVO)

5.2. Incident-Response-Management

Folgende Maßnahmen sollen gewährleisten, dass im Fall von Datenschutzverstößen Meldeprozesse ausgelöst werden:

- Meldeprozess für Datenschutzverletzungen nach Art. 4 Ziffer 12 DSGVO gegenüber den Aufsichtsbehörden (Art. 33 DSGVO)
- Meldeprozess für Datenschutzverletzungen nach Art. 4 Ziffer 12 DSGVO gegenüber den Betroffenen (Art. 34 DSGVO)
- Einbindung des Datenschutzbeauftragten in Sicherheitsvorfälle und Datenpannen

- Einsatz von Anti-Viren-Software

5.3. Datenschutzfreundliche Voreinstellungen (Art. 25 Abs. 2 DSGVO)

Die folgenden implementierten Maßnahmen tragen den Voraussetzungen der Prinzipien "Privacy by design" und "Privacy by default" Rechnung:

- Schulung der Mitarbeiter im "Privacy by design" und "Privacy by default"
- Es werden nicht mehr personenbezogene Daten erhoben, als für den jeweiligen Zweck erforderlich sind.

5.4. Auftragskontrolle

Durch folgende Maßnahmen ist sichergestellt, dass, dass personenbezogene Daten nur entsprechend der Weisungen verarbeitet werden können:

- Schriftliche Weisungen an den Auftragnehmer oder Weisungen in Textform (z.B. durch Auftragsverarbeitungsvertrag)
- Sicherstellung der Vernichtung von Daten nach Beendigung des Auftrags, z.B. durch Anfrage entsprechender Bestätigungen
- Bestätigung von Auftragnehmern, dass sie ihre eigenen Mitarbeiter auf das Datengeheimnis verpflichten (typischerweise im Auftragsverarbeitungsvertrag)
- Sorgfältige Auswahl von Auftragnehmern (insbesondere hinsichtlich Datensicherheit)
- Die Datenverarbeitung zur Konfessionszugehörigkeit erfolgt ausschließlich zu dem Zweck der Lohnabrechnung und der ordnungsgemäßen Abführung der Kirchensteuer. Jede andere Nutzung dieser Daten ist untersagt.

Anlage 4 – Aktuelle Subunternehmer

Kritische Subunternehmer:

Name	Funktion	Serverstandort
Supabase Inc.	Datenbank-Provider	Frankfurt, Deutschland (eu-central-1)
Vercel Inc.	Frontend-Hosting	Frankfurt, Deutschland (fra1)
Wegmayer IT Gmbh	Entwicklerteam	Serverstandort DE
TwoForWeb LLC	Entwicklerteam	Kein Serverstandort

Infrastruktur-Provider:

Resend Inc.	E-Mail-Service mit Personendaten	Serverstandort USA
Amazon Web Services	Cloud-Infrastruktur	Frankfurt, Deutschland (eu-central-1)
Deno Deploy	Edge Computing	Edge Network weltweit